



Defender's Agreement

{today}

Agreement between Defend Denmark ApS and {defender}

Introduction

This agreement is between Defend Denmark ApS. CVR 45824578, hereinafter referred to as **The Company**, and its security researcher, hereinafter referred to as **The Defender**. The agreement outlines the definition of good faith within the context of identifying and reporting vulnerabilities and clarifies what the Defender can expect from the Company in return. In addition to a vulnerability policy, this agreement includes provisions related to confidentiality, ethical communication and reward payments.

This agreement comes into force with the signature of both parties and is in effect from the date of the later signature.

Good Faith

All conduct of the Defender for the Company must be made in good faith, that is, the Defender must ensure all conduct is honest and in line with the agreed upon guidelines and testing methods outlined in this agreement. A good faith conduct does not infringe upon the confidentiality or the ethical clauses of this agreement and is entirely within the scope of the relevant campaigns the Defender partakes in, nor does it disregard the interest of the Company and its customers. Participants agree to act in good faith, promoting a positive and respectful atmosphere. Reporting any violations promptly is essential for maintaining trust and accountability.

Authorization

By signing this agreement the Company and its customers will consider your research, if made in good faith and in accordance with this agreement and any relevant campaigns, to be authorised.

While the Defender's conduct is within the four corners of this agreement, the Company will provide you with assistance in your research and make efforts to ensure that issues are resolved quickly as well as recommend no legal action to be taken related to the Defender's good faith research.

Should legal action be initiated against the Defender by a third party for activities that were conducted in good faith and accordance with this agreement, the Company will inform that third party of this authorization and its scope, and make best effort to provide legal assistance; however, any such assistance is dependent on the Defender's full compliance with this agreement and adherence to Danish law.

Guidelines

Under this agreement, "research" means activities in which the Defender:

- Does not disrupt or degrade the customer's products and services.
- Notifies us as soon as possible after the Defender discovers a real or potential security issue.
- Makes every effort to avoid privacy violations, degradation of user experience, disruption to production systems, and/or destruction or manipulation of data.
- Only uses exploits to the extent necessary to confirm a vulnerability's presence.

- Does not use an exploit to compromise or exfiltrate data, establish command line access and/or persistence, or use the exploit to pivot to other systems.
- Does not replicate, reproduce, or recreate any method, tool, or process used during the research for any purpose other than the agreed-upon scope of work. This includes but is not limited to sharing code snippets, scripts, or step-by-step instructions with third parties.
- Provides a reasonable amount of time (typically 90 calendar days) to resolve the issue before any coordinated disclosure with the Company.
- Does not submit a high volume of low-quality reports.
- If the Defender is employed by a customer of the Company, the Defender is strictly prohibited from participating in that bug bounty program through the Company's platform. This includes any testing, reporting, or disclosure of security vulnerabilities within the customer's systems, applications, or services.
- Once the Defender has established that a vulnerability exists or the Defender encounters any sensitive data (including Personal Data (PD), medical information, financial information, or proprietary information or trade secrets of any party), the Defender **must stop** their tests and report any vulnerabilities immediately.

Testing Methods

Please apply skills and tools diligently, keeping in mind the importance of responsible testing practices. Be aware that the Company's goal is to enhance security while avoiding any unintended disruptions.

In addition to any prohibited activities in the guidelines above, the following test methods are not authorised, unless specific rules within the Company's platform say otherwise:

- Network denial or distributed denial of service (DoS or DDoS) tests or other tests that impair access to or damage a system or data.
- Physical testing (e.g., office access, open doors, tailgating), social engineering (e.g., phishing, vishing), or any other non-technical vulnerability testing.
- Testing on internal networks is not allowed. All testing must be done against externally (e.g. accessible from the Internet) accessible systems only.

Scope

The scope of the security research applies to all the Company's and its customers externally accessible systems and services. The information about customers and scope for each customer can be found on the platform in the customer specific policy and also in the customer program on the platform.

If the Defender isn't sure whether a system is in scope or not, contact info@defenddenmark.dk or reach out on a Discord channel, before starting research.

The Company asks that active research and testing only be conducted on the systems and services covered by the scope of this agreement. If there is a particular system not directly listed in scope that the Defender thinks merits testing, please contact the Company to discuss it first. When in doubt, assume out of scope.

Reporting a vulnerability

Information submitted under this agreement will be used for defensive purposes only – to mitigate or remediate vulnerabilities. If the Defender's findings include newly discovered vulnerabilities that affect all users of a product or service and not solely the Company or the defined scope for the Company's customers, or if the vulnerability could affect important infrastructure, the Company may share the Defender's report directly with the vendor and SAMSIK, or relevant CERT units in Denmark . There it will be handled under their internal disclosure process. The Company will never share the Defender's name or other personal data to a third party without the Defender's explicit permission.

The Company accepts vulnerability reports through its platform and will acknowledge submission of reports within minutes.

Confidentiality

The Defender is bound by confidentiality regarding all information they encounter during their research, with no exceptions. The confidentiality applies to all data, documents, reports, and findings obtained during the security research assessments. The types of confidential information are endless, including but not limited to system architecture details, source code, user data, vulnerabilities discovered and security measures. The Defender is prohibited from disclosing, using, or exploiting this information except as necessary for the performance of their duties.

The Defender is also bound by Danish and European law, to the extent applicable, including but not limited to the Danish Financial Business Act (Lov om finansiel virksomhed), the Danish Data Protection Act (Databeskyttelsesloven), and the underlying GDPR. The Defender agrees to handle any personal data encountered during assessments in accordance with legal requirements.

Being bound by confidentiality, the Defender commits to infinitely follow these obligations:

- Confidentiality: Keeping all information received confidential and not disclosing it to any unauthorised parties.
- Data Protection: Handling personal data with care, ensuring compliance with GDPR principles (lawfulness, fairness, transparency, purpose limitation, etc.).
- Transparency: Providing a transparent and comprehensive vulnerability assessment report to the Company.
- No Unauthorised Use: Not using any information for personal gain or any purpose beyond the scope of the guidelines.

Termination of this agreement does not affect the Defender's ongoing obligations regarding confidential information. In the event of breach, the Defender shall indemnify the Company for any losses resulting from such breach. The Company reserves the right to seek legal remedies, including injunctive relief and damages.

Ethical Communication

Purpose and Intent:

This clause outlines the expectations and ethical standards for the Defender in the Company's program. It applies to all interactions within the program, whether online, in person, or during program-related activities.

In addition to prohibitions outlined in other clauses of this agreement, the Defender is strictly prohibited from engaging in the following actions:

- Defamatory Statements: Making false, harmful, or disparaging statements about other participants, the Company's staff, the Company's customers or any third party.
- Harassment: Engaging in any form of harassment, including but not limited to bullying, discrimination, or intimidation.
- Disclosure of Confidential Information: As per further description in the confidentiality clause.
- Unprofessional Behaviour: Behaving in a manner inconsistent with the program's values, including offensive language, personal attacks, or disruptive behaviour.

Communication Channels:

- Online Platforms:
 - All communication on program-related platforms (such as forums, chat groups, or social media) must adhere to ethical standards.
 - The Defender should maintain a respectful tone, avoid inflammatory language, and promote positive interactions.
- In-Person Interactions:
 - Face-to-face interactions during program events should reflect professionalism, courtesy, and respect.
 - The Defender should uphold the program's reputation through their behaviour.
- Between Participants:
 - Ethical communication extends to all interactions between Defenders.
 - Active listening, empathy, and constructive dialogue are encouraged.
 - Participants should foster a supportive and collaborative environment.

Consequences of Breach:

If a participant violates this agreement, the program organisers reserve the right to take appropriate actions:

- Warning: Issuing a formal warning to the offending participant.
- Suspension: Temporarily suspending program privileges.
- Termination: Removing the participant from the program if the breach significantly impacts the program's integrity.

Legal Consequences and Support Obligations

In the case of a serious violation of this Agreement, and/or cause of loss in any way to the Company, it can lead to the Company taking legal actions against the undersigned. Should the Company be held liable in any way,

the undersigned shall provide the utmost support possible in order to minimise the loss.